第 15 章練習　安全

本檔只含題目。請先自行建立狀態或變數表，再作答；解答在獨立檔案。

OS15-E01　越界與防禦邊界

容量12-byte的C字串目的buffer，輸入data長12；本題不假設實際ABI配置。

1. 連NUL完整複製需要幾bytes？兩種正確契約如何處理？
2. NX可否阻止此次越界？

OS15-E02　DoS 的 pending slots

有 2000 個 pending slots。假設系統處於有限穩態，在相同的觀測邊界內，每筆被接受的未完成請求平均保留 8 秒，無提前清除，平均佔用恰為 2000。

1. 用 Little 定律求被接受請求的平均速率；這能否單獨決定外部提供的到達率或首次滿槽時間？
2. 按source IP限制可能傷害誰？

OS15-E03　重用 keystream

m1=0x10，m2=0x70，s=0xA5，c=m XOR s。

1. 算兩ciphertexts、其XOR，已知m1如何解m2？
2. 此推理是否依賴暴力破解cipher？

OS15-E04　RSA 的非互質明文

p=5、q=11、n55、e3、d27；令m=5。

1. 算cipher與decrypt並列平方表。
2. 因gcd(5,55)≠1，為何仍正確？

OS15-E05　MAC、hash 與 replay

接收方收到 (m,H(m))、(m,MACk(m))，或將 session、訊息 m 與唯一 nonce 以無歧義編碼綁入 MAC 的資料。nonce 起初為 pending；假設金鑰未洩漏且 MAC 安全。

1. 為何公開hash不能認證？MAC又為何不自動防重放？
2. 兩個 thread 同時驗到 pending nonce，如何避免雙接受？這是否保證外部付款效果恰好一次？

Lin Cing https://github.com/xinhi6716/computer-science-self-study

OS15-E06　歷史 TLS 的身分與forward secrecy

使用 TLS 1.2 的 static RSA key exchange 完整握手；對手錄下 ClientKeyExchange、兩端 hello random 與相關握手封包。客戶端依正確信任根檢查憑證鏈、名稱及用途，並驗證 server Finished。兩年後 server 的 static RSA private key 外洩。

1. certificate簽章有效是否足以當下確認server持private key？
2. 先前錄到的session是否因已刪traffic key就必然安全？

OS15-E07　Salt 與猜測成本

500筆各有不同salt；每筆字典20000候選；KDF每次2 ms，單一工作單元串行。

1. 完整字典最多需幾次KDF、多少時間？salt是否秘密？
2. online每帳號每秒一次的limit是否把上述offline時間改成10000000 s？

OS15-E08　IDS 的 base rate

共有 100000 個事件，攻擊先驗比例 0.001；TPR=0.9，FPR=0.01。以下 counts 是依條件率計算的期望值，precision 定義為母體條件機率 P(attack | alarm)。

1. 列期望 TP/FN/FP/TN，並求母體 precision；它是否必為有限樣本中隨機比值 TP/(TP+FP) 的期望？
2. 固定TPR與base rate，要precision至少50%，FPR應≤多少？

OS15-E09　Firewall 真正允許什麼

採正文 first-match 三區政策：已追蹤連線、Internet→web TCP 443、web→DB TCP 5432，其餘拒絕。前三個測試封包均為新連線且無現存狀態；最後一個 DB→web 回應確實匹配既存允許連線的反向五元組與狀態。

1. 依序判斷新 Internet→DB TCP 5432、新 web→DB TCP 5432、新 web→DB TCP 22，以及上述既存回應。
2. web遭入侵後是否不能觸DB？

OS15-E10　Windows7 ordered DACL 與 MIC

r、w 是互不重疊、已完成 generic mapping 的 specific access masks；不考慮 owner、privilege、restricted-token 或其他額外強制限制。token 的 user SID 為 U，群組 G 的 SID 已啟用且適用於相關 ACE；token IL=low，物件 IL=medium，mandatory policy 只有 NO_WRITE_UP。

1. DACL=[deny(G,w),allow(U,rw)]，request r與rw分別如何？
2. 把allow U,rw刻意放前，DACL對rw如何？最終write又如何？
3. NULL DACL與empty DACL如何不同？

參考資料與署名

Lin Cing，《作業系統》手寫筆記。 Silberschatz et al., Operating System Concepts, 9th ed., Ch. 15. RFC 5246. RFC 7568. Microsoft: DACL. Microsoft: MIC.

Lin Cing 原創教學整理，原創內容以 CC BY 4.0 授權。

https://github.com/xinhi6716/computer-science-self-study

Lin Cing
https://github.com/xinhi6716/computer-science-self-study